
COURSE	CECS 378	TERM	Su26
EXAM	Exam 1	POINTS	60

Exam 1 — Introduction to Computer Security

 **PRINT CLEARLY. UNNAMED EXAMS CANNOT BE RETURNED OR GRADED.**

NAME: _____

STUDENT ID#: _____ **DATE:** _____

 **Directions.** Write on the exam paper. **Multiple choice:** circle the single best answer. **True/False:** circle the correct option, (a) True or (b) False. **Short answer:** write in the space provided. You may use one 3"×5" card of notes (both sides, handwritten only). **No electronic devices of any kind are allowed on your desk during the exam.**

SECTION 1 — Multiple Choice (4 pts each, 20 pts total)

1. (4 pts) Which of the following best describes a **symmetric-key cipher**?
 - (a) The sender encrypts with a public key; the receiver decrypts with a private key.
 - (b) The same secret key is used for both encryption and decryption.
 - (c) No key is required; security relies entirely on algorithm secrecy.
 - (d) A digital signature is produced as a side effect of encryption.
2. (4 pts) A cryptographic hash function is said to be **collision resistant** if:
 - (a) Given a hash value, it is computationally infeasible to find any input that produces it.
 - (b) The hash output is exactly the same length as the input.
 - (c) It is computationally infeasible to find two distinct inputs that produce the same hash output.
 - (d) The hash function runs in constant time regardless of input length.
3. (4 pts) In RSA, a message is encrypted for a recipient by using:
 - (a) The sender's private key.
 - (b) A shared session key negotiated via Diffie-Hellman.
 - (c) The recipient's private key.
 - (d) The recipient's public key.
4. (4 pts) A classic **stack buffer overflow** typically overwrites which memory region to redirect control flow?
 - (a) The heap allocation header.
 - (b) The process's environment variables.
 - (c) The saved return address on the stack frame.
 - (d) The kernel's system-call dispatch table.
5. (4 pts) The **principle of least privilege** states that:
 - (a) A subject should be granted the maximum privileges needed for any possible future task.

- (b) All users must share a single privileged account to simplify auditing.
- (c) Privileges are determined by a mandatory label assigned at object creation time.
- (d) A subject should be granted only the minimum privileges necessary to perform its current task.

SECTION 2 — True / False (2 pts each, 10 pts total)

- 6. (2 pts) T / F. AES is an example of an asymmetric (public-key) cipher.
 - (a) True
 - (b) False
- 7. (2 pts) T / F. A cryptographic hash function maps an arbitrary-length input to a fixed-length output.
 - (a) True
 - (b) False
- 8. (2 pts) T / F. To send a confidential message with RSA, the sender encrypts it with their own private key.
 - (a) True
 - (b) False
- 9. (2 pts) T / F. A non-executable stack (NX / W $\oplus$ X) by itself defeats return-oriented programming (ROP) attacks.
 - (a) True
 - (b) False
- 10. (2 pts) T / F. The principle of least privilege limits the damage a compromised process can cause.
 - (a) True
 - (b) False

SECTION 3 — Short Answer (10 pts each, 30 pts total)

- 11. (10 pts) Briefly explain **why symmetric ciphers are generally used to encrypt bulk data** in practice, while asymmetric ciphers are typically used only for key exchange or digital signatures. What fundamental trade-off motivates this hybrid design?

-
12. (10 pts) Name and briefly describe **two** OS/compiler-level mitigations for stack buffer overflow attacks. For each mitigation, also state one way an attacker might attempt to circumvent it.

13. (10 pts) Compare **Discretionary Access Control (DAC)** and **Mandatory Access Control (MAC)**. For each model: (i) who controls access decisions, and (ii) give one concrete example of a system or OS feature that uses it.

End of exam. Total: 60 points.